

Comprehensive Cybersecurity Fundamentals

Core concepts and major cybersecurity domains for the CyberRAG knowledge base

1. Cybersecurity Overview

Cybersecurity is the practice of protecting computers, networks, applications, cloud services, devices, and information from unauthorized access, misuse, disruption, modification, or destruction. Effective cybersecurity combines people, processes, and technology rather than relying on a single security product.

2. CIA Triad

The CIA triad represents three fundamental security objectives. **Confidentiality** means information is accessible only to authorized parties. **Integrity** means information remains accurate and protected from unauthorized alteration. **Availability** means authorized users can access systems and information when needed.

3. Authentication, Authorization and Accounting

Authentication verifies identity, for example through passwords, hardware tokens, biometrics, or multi-factor authentication. Authorization determines what an authenticated identity is allowed to do. Accounting or auditing records relevant actions so activity can be reviewed and investigated.

4. Access Control and Least Privilege

Access control restricts resources to authorized identities. Common models include role-based access control and attribute-based access control. The principle of least privilege gives users and systems only the permissions necessary for their legitimate tasks. Separation of duties reduces the risk that one person can perform an entire sensitive process without oversight.

5. Network Security

Network security protects communication and network infrastructure. Important controls include firewalls, network segmentation, secure routing and switching, VPNs, intrusion detection and prevention systems, secure Wi-Fi, monitoring, and access control. Segmentation can limit lateral movement when a device is compromised.

6. Firewalls, IDS and IPS

A firewall applies rules to permit, deny, or inspect network traffic. An intrusion detection system identifies suspicious or malicious activity and generates alerts. An intrusion prevention system can also take automated action to block or limit detected activity. These controls require proper configuration and monitoring.

7. Web Application Security

Web security focuses on protecting websites, APIs, user sessions, and backend services. Common risks include injection flaws, cross-site scripting, broken access control, authentication failures, insecure configuration, vulnerable components, and insecure APIs. Defensive practices include input validation, parameterized queries, output encoding, authorization checks, secure session handling, dependency management, and security testing.

8. Cryptography Fundamentals

Cryptography protects information using mathematical techniques. Encryption protects confidentiality by transforming plaintext into ciphertext. Symmetric encryption generally uses the same secret key for encryption and decryption. Asymmetric cryptography uses related public and private keys. Hash functions create fixed-length

representations useful for integrity checking. Digital signatures help provide integrity and authentication.

9. Public Key Infrastructure and Certificates

Public key infrastructure supports management and use of digital certificates and public keys. Certificates bind identities to public keys and are commonly used with TLS to establish secure communications. Correct certificate validation and secure protection of private keys are essential.

10. Password Security and Multi-Factor Authentication

Strong password practices include using long, unique passwords and avoiding password reuse. Password managers can help generate and store unique credentials. Multi-factor authentication combines different factors such as something known, possessed, or inherent, reducing the impact of password compromise.

11. Vulnerability Management

Vulnerability management is a continuous process of discovering assets, identifying weaknesses, assessing risk, prioritizing remediation, applying patches or mitigations, and verifying results. Not every vulnerability has equal urgency; prioritization should consider exposure, exploitability, business importance, and potential impact.

12. Patch and Configuration Management

Patch management keeps software and firmware updated to address known defects and vulnerabilities. Configuration management establishes secure baselines and controls changes. Misconfiguration, unnecessary services, default credentials, and excessive permissions can create serious risk even when systems are fully patched.

13. Endpoint Security

Endpoints include laptops, desktops, servers, and mobile devices. Endpoint security may include anti-malware, endpoint detection and response, disk encryption, application control, secure configuration, patching, and centralized logging. Monitoring suspicious processes and behavior can help detect attacks that bypass simple signatures.

14. Cloud Security

Cloud security protects cloud-hosted infrastructure, applications, identities, and data. Common risks include excessive permissions, exposed storage, leaked credentials, insecure APIs, and inadequate logging. Security responsibilities may be shared between the cloud provider and customer depending on the service model.

15. Application and Secure Software Development

Secure software development integrates security throughout planning, design, coding, testing, deployment, and maintenance. Practices include threat modeling, code review, dependency management, automated testing, secret management, and remediation of discovered vulnerabilities.

16. Security Monitoring and Logging

Logs record security-relevant events such as authentication attempts, configuration changes, process execution, network connections, and application errors. Centralized monitoring can correlate events and identify suspicious patterns. Logs should be protected, retained appropriately, and synchronized with reliable time sources.

17. Incident Response

Incident response is a structured approach to handling security events. Typical activities include preparation, detection and analysis, containment, eradication, recovery, and lessons learned. Clear roles, communication procedures, evidence handling, and practiced recovery plans improve response effectiveness.

18. Digital Forensics

Digital forensics involves identifying, preserving, collecting, examining, and analyzing digital evidence. Important principles include maintaining evidence integrity, documenting actions, using appropriate procedures, and preserving relevant logs or artifacts. Forensics can support incident investigation, root-cause analysis, and legal or organizational processes.

19. Backup and Disaster Recovery

Backups support recovery from ransomware, accidental deletion, hardware failure, and other incidents. A useful backup strategy includes regular testing and protection against unauthorized modification. Disaster recovery planning focuses on restoring important services within acceptable time and data-loss objectives.

20. Risk Management

Risk management identifies important assets, threats, vulnerabilities, potential impacts, and likelihood. Organizations then choose to mitigate, transfer, avoid, or accept risks based on priorities and available resources. Security controls should be aligned with actual risks rather than applied randomly.

21. Security Governance and Policies

Governance establishes accountability and direction for cybersecurity. Policies define expectations; standards describe mandatory requirements; procedures provide detailed steps. Effective governance also includes asset management, risk assessment, awareness, compliance where applicable, and regular review.

22. Threat Intelligence

Threat intelligence provides context about adversaries, campaigns, tactics, techniques, indicators, and vulnerabilities. It can support prioritization, detection, threat hunting, and incident response. Useful intelligence should be relevant, timely, and actionable rather than merely a large collection of indicators.

23. Security Awareness

Human behavior is an important part of cybersecurity. Awareness programs can teach users to recognize phishing, protect credentials, report suspicious events, handle sensitive information correctly, and verify unusual requests. Awareness works best when combined with technical controls rather than used as the only defense.

24. Defense in Depth

Defense in depth uses multiple layers of security so failure of one control does not automatically result in complete compromise. Layers can include identity controls, secure configuration, network segmentation, endpoint protection, encryption, monitoring, backups, and incident response.

25. Zero Trust Concepts

Zero trust emphasizes continuous verification rather than assuming that network location alone establishes trust. Access decisions should consider identity, device state, context, and the requested resource. Least privilege and segmentation are commonly associated with this approach.

26. Common Cybersecurity Career Domains

Cybersecurity roles include security analyst, security engineer, penetration tester, incident responder, digital forensic analyst, threat intelligence analyst, cloud security engineer, application security specialist, security architect, governance and compliance specialist, and security researcher.

27. Core Security Best Practices

Maintain an inventory of important assets. Keep software updated. Use strong unique credentials and MFA. Apply least privilege. Encrypt sensitive information where appropriate. Segment networks. Monitor important systems. Maintain tested backups. Train users to recognize social engineering. Regularly assess security controls and practice incident response.

28. Summary

Cybersecurity is a broad discipline that protects information and digital systems through preventive, detective, responsive, and recovery controls. The most effective approach combines secure technology, well-defined processes, informed users, continuous monitoring, and regular improvement based on changing risks.

CyberRAG Knowledge Base Note: This document is structured as focused sections covering foundational cybersecurity concepts. It can complement specialized documents on threats, malware, web security, networking, incident response, and digital forensics.